5. 密钥碎片化存储与恢复机制

为保障 AI Agent 去中心化身份（DID）对应的密钥安全，解决密钥单点存储易丢失、易泄露的核心痛点，响应审核要求，AID Protocol 采用 Shamir 秘密共享技术，设计一套安全、可靠、可恢复的密钥碎片化存储与恢复机制，兼顾安全性、可用性与合规性，确保 Agent 身份资产不丢失、不被篡改。

5.1 核心设计原则

本机制遵循“去中心化存储、阈值恢复、链上可验证、多路径备份”四大核心原则，既避免密钥明文集中存储的安全风险，又解决碎片丢失导致的身份锁死问题，同时符合 W3C DID 隐私与安全规范，满足审核对密钥安全的核心要求：

- 去中心化存储：密钥不集中存储于单一设备或服务器，分散为多碎片，降低单点故障与泄露风险；
- 阈值恢复：碎片满足预设阈值即可恢复主密钥，无需集齐所有碎片，提升恢复灵活性；
- 链上可验证：碎片相关信息（哈希值、版本）上链存证，确保碎片合法性、防篡改；
- 多路径备份：结合本地、用户托管、链上加密备份等多种方式，全方位防止碎片丢失。

5.2 密钥碎片化存储方案

AID Protocol 采用行业标准的 Shamir 秘密共享算法，将 Agent 身份对应的主密钥（私钥）进行碎片化处理，具体实现如下：

5.2.1 密钥分片规则

1. 主密钥拆分：将 Agent 核心私钥（用于 DID 签名、身份验证）拆分为 N 个加密碎片（默认采用 3/5 阈值模式，即拆分为 5 个碎片，集齐 3 个即可恢复主密钥），支持根据用户需求灵活配置阈值（如 2/3、4/6 等）；

2. 碎片加密处理：每个碎片均采用 AES-256 加密算法进行二次加密，加密密钥由用户自主控制，确保碎片本身不可被非法解析；

3. 碎片哈希存证：将每个碎片的哈希值、分片规则、阈值参数等信息，加密后上传至区块链存证，用于后续碎片合法性校验，不上传任何原始碎片数据，保障隐私安全。

5.2.2 多路径碎片存储位置

为彻底解决碎片丢失问题，采用多维度分散存储策略，每个碎片存储于不同位置，避免单一设备损坏、丢失导致的碎片不可用：

1. 本地设备碎片（核心碎片）：1-2 个碎片存储于 Agent 所在本地设备（如终端服务器、边缘设备），采用本地加密存储，仅 Agent 自身可访问，不与外部网络直接交互；

2. 用户托管碎片：1 个碎片由用户通过加密方式托管（如用户手机加密存储、硬件钱包、离线 U 盘），作为本地碎片的备份补充；
3. 链上加密碎片（校验碎片）：1 个碎片经过多重加密后，仅上传加密片段（非原始碎片），结合链上哈希校验，用于恢复时的合法性验证，不具备单独恢复主密钥的能力；
4. 可选备份碎片：1 个碎片可由用户授权可信第三方（如合规存储服务商）进行加密备份，或采用社交恢复模式（由用户指定的可信联系人托管），进一步降低丢失风险。

5.2.3 碎片防丢失保障

为进一步降低碎片丢失概率，配套多重防丢失机制，确保碎片可追溯、可备份：

- 自动备份提示：当本地碎片未备份、存储设备异常时，系统自动提醒用户进行碎片备份，支持碎片导出为加密文件、打印助记词（助记词对应碎片加密密钥）；
- 碎片版本管理：链上记录碎片的版本信息，当碎片更新、备份后，自动同步版本哈希，防止旧碎片失效导致的恢复失败；
- 异常监测：实时监测碎片存储状态，当某一位置的碎片丢失、被篡改时，立即提醒用户，同步触发备用碎片激活机制；
- 离线备份支持：支持用户将碎片导出为离线加密文件，存储于离线设备，彻底隔离网络风险，应对极端场景下的碎片恢复需求。

5.3 碎片恢复功能实现

针对碎片丢失、设备损坏等场景，设计完整的碎片恢复流程，确保用户可通过合法途径快速恢复主密钥，保障 Agent 身份正常使用，同时防范非法恢复攻击：

5.3.1 恢复触发条件

当满足以下任一条件时，用户可发起碎片恢复请求：

- 本地设备损坏、丢失，导致本地碎片不可用；
- 某一存储位置的碎片丢失、被篡改，无法满足阈值要求；
- 用户更换设备，需要将密钥碎片迁移至新设备；
- 异常场景下（如密钥泄露风险），需要通过碎片恢复重新生成主密钥。

5.3.2 恢复流程（阈值恢复模式）

1. 恢复发起：用户通过合法身份验证（如 DID 签名、用户密码、生物识别），发起碎片恢复请求，明确恢复场景；
2. 碎片收集：用户上传已有的合法碎片（满足阈值数量），系统通过链上哈希存证，校验每个碎片的合法性、完整性，排除被篡改、伪造的碎片；

3. 密钥恢复：系统采用 Shamir 算法，通过集齐的阈值碎片，反向计算恢复主密钥，恢复过程全程在本地完成，不将任何碎片、主密钥上传至服务器；
4. 恢复校验：主密钥恢复后，系统自动发起链上校验，验证恢复后的主密钥与 Agent DID 的绑定关系，确保恢复结果正确；
5. 碎片重分配：恢复成功后，系统自动重新拆分主密钥为新的碎片，同步更新各存储位置的碎片，删除旧碎片，提升安全性；
6. 行为记录：所有碎片恢复操作（发起时间、恢复方式、碎片来源）均上链存证，用于安全审计，防范非法恢复行为。

5.3.3 恢复安全保障

为防范非法恢复、碎片伪造等攻击，配套多重安全校验机制：

- 身份校验：恢复前必须完成 Agent 身份与用户身份的双重验证，确保恢复请求的合法性；
- 碎片校验：通过链上哈希值、分片规则，校验每个上传碎片的真实性，拒绝伪造、篡改的碎片；
- 异常拦截：当检测到异常恢复行为（如短时间内多次发起恢复、碎片来源异常），立即拦截恢复请求，触发人工审核；
- 离线恢复支持：支持离线环境下的碎片恢复，无需联网，避免网络攻击导致的恢复失败或密钥泄露。

5.4 审核合规说明

本密钥碎片化存储与恢复机制，完全响应审核提出的“防止碎片丢失及碎片恢复”要求，同时符合去中心化身份的安全与合规标准：

- 解决碎片丢失问题：通过多路径存储、自动备份、离线备份等机制，确保单一碎片丢失不影响主密钥恢复，避免 Agent 身份永久锁死；
- 防范碎片泄露风险：采用加密分片、链上哈希存证、本地处理等方式，确保碎片不被非法获取、解析，保障密钥安全；
- 合规性保障：符合 W3C DID 隐私保护规范，所有碎片存储、恢复操作可追溯、可审计，满足数据安全与合规要求；
- 可用性保障：阈值恢复模式兼顾安全性与可用性，用户无需集齐所有碎片即可完成恢复，降低使用门槛。

5.5 模块归属与实现计划

本机制归属 AID Protocol 核心模块——**Agent 密钥管理模块（AgentKeyManager）**，对应智能合约代码将在项目冷启动第 16-18 天完成开发，具体实现计划如下：

1. 第 16 天：完成 Shamir 密钥分片算法的智能合约实现，支持自定义阈值与分片数量；
2. 第 17 天：实现碎片加密、链上哈希存证功能，完成多路径存储逻辑开发；

3. 第 18 天：完成碎片恢复流程、安全校验机制开发，与 Agent DID 身份模块联动调试，确保功能可用。

相关代码将存储于项目 GitHub 仓库的 contracts/AgentKeyManager.sol 文件中，开源可审计，接受社区与审核方的监督。

（注：文档部分内容可能由 AI 生成）